# ZDI-26-897: (Pwn2Own) Home Assistant Green aiohttp_client Server-Side Request Forgery Vulnerability

Report Type: Weekly · Generated: November 07, 2026 11:49 UTC · Coverage: Nov 06 - Nov 07, 2026

| 1 | 0 | 0 | 0 |
|---|---|---|---|
| Total Advisories | Critical | High | Medium |

| LOW | N/A | TLP:CLEAR | PRO |
|---|---|---|---|
| Severity | CVSS / Risk Score | TLP Classification | Customer Tier |

## Executive Summary

[P4] Vulnerability - low severity (Risk 0.9/10). No MITRE ATT&CK techniques mapped - limited adversarial context. 42 indicators detected - upgrade to Pro for full IOC access. Actor attribution: Vulnerability Exploitation Cluster. AI confidence: LOW (31%) - limited source data available.

**CONFIDENTIALITY NOTICE:** This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

## Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

| Advisory Title | Severity | CVSS | EPSS | AI Summary |
|---|---|---|---|---|
| ZDI-26-897: (Pwn2Own) Home Assistant Green aiohttp Client Server-Side | LOW | - | - | [P4] Vulnerability - low severity (Risk 0.9/10). No MITRE ATT&CK |

## MITRE ATT&CK® v15 Mapping

Technique density score: **0.0** · Techniques observed: **0** · Tactics covered: **0**

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

## Threat Actor Intelligence

Attribution analysis across advisories in this report period.

| Threat Actor | Count | Associated CVEs / Indicators |
|---|---|---|
| UNC-CDB | 1 | - |

## Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intel/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

## Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

### Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - CDB-ADVISORY Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: Detects exploitation indicators related to CDB-ADVISORY.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/11/07
tags:
- attack.initial_access
- attack.t1190
logsource:
category: webserver
detection:
keywords:
- 'CDB-ADVISORY'
condition: keywords
falsepositives:
- Security testing / penetration testing
level: medium
```

### Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - ZDI-26-897: (Pwn2Own) Home Assistant Green aiohttp_client Server-Side Request Forgery Vulnerability
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "ZDI-26-897: (Pwn2Own) Home Assistant Gre"
or AlertName has "ZDI-26-897: (Pwn2Own) Home Assistant Gre"
or ExtendedProperties has "ZDI-26-897: (Pwn2Own) Home Assistant Gre"
| extend Rule = "APEX-ADVISORY", Severity = "LOW"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

## Incident Response Playbook

**Phase 1 - 0-24 Hours (Containment)**

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield ZDI instances exposed to the internet.
3. Enable verbose access logging on all ZDI endpoints immediately.
4. Pull last 72h of web server and application logs for forensic baselining.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
6. Notify relevant internal stakeholders and legal / compliance team.

### Phase 2 - 24-72 Hours (Eradication)

1. Apply vendor patch for ZDI or implement recommended mitigation.
2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
3. Rotate all API keys, service account credentials, and session tokens.
4. Conduct forensic timeline reconstruction for potential compromise window.
5. Validate patch deployment across 100% of affected instances via asset inventory.

### Phase 3 - 7 Days (Recovery & Hardening)

1. Conduct post-incident review and update incident response runbooks.
2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
3. Update asset inventory with patched version information and closure evidence.
4. Submit findings to internal risk register and CISO dashboard.
5. Schedule follow-up vulnerability scan to confirm remediation completeness.

## Financial Impact Analysis (FAIR Model)

| $20K - $180K | $60K | $25K/day | N/A |
|---|---|---|---|
| Breach Cost Range (FAIR) | IBM Cost of Breach 2025 Median | Business Interruption Cost | Regulatory Fine Exposure |

Low severity findings require targeted patches. Aggregated low-severity debt compounds to medium breach probability within 12 months.

**Remediation Cost Estimate:** $15K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

## Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

| Framework | Reference | Obligation |
|---|---|---|
| **ISO 27001:2022** | A.8.8 | Track and remediate within standard 90-day patch cycle |
| **NIST CSF 2.0** | ID.RA | Include in regular vulnerability risk assessment |

## Actionable Recommendations

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Prioritized defensive actions based on this period's intelligence.

1. Monitor ZDI-26-897: (Pwn2Own) Home Assistant Green aiohttp_client Server-Side Request Forgery Vulnerability for escalation.
2. Apply patches in next maintenance window.
3. Apply vendor patch for ZDI-26-897: (Pwn2Own) Home Assistant Green aiohttp_client Server-Side Request Forgery Vulnerability immediately - check NVD for official fix guidance.
4. Enable enhanced logging and alerting on all systems running affected software versions.
5. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
6. Audit all internet-facing instances of affected products and confirm patch deployment.
7. Conduct a threat hunt using MITRE ATT&CK techniques mapped in this advisory.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

## Appendix - Report Metadata & Legal

| Field | Value |
|---|---|
| Report ID | intel--650bad44cfb32442e8817d0b |
| Report Type | Weekly |
| Platform | CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE |
| Generated At | 2026-11-07T11:49:25.96685 |
| Customer Tier | PRO |
| Customer Email | - |
| TLP | TLP:CLEAR |
| STIX Version | 2.1 |
| ATT&CK Version | v15 |

### Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries: contact@cyberdudebivash.in

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY